

SIMATS ENGINEERING

ASSESSMENT TOOL 1 – Enumeration Analysis

COURSE CODE: ITA14	COURSE NAME: Ethical Hacking
Questions: 5	Total Marks: 100
Reg. No: 192521434	Name: P Delhi Ganesh

CO3: Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL3)

Assessment Tool Weightage: 40%

Q1. Enumeration of scanme.nmap.org (Public-Facing Server)

1. Nmap Commands Used

- **Host discovery:** nmap -sn scanme.nmap.org — verifies the host is alive using ping/ARP-style probes
- **TCP port scan:** nmap -p- -T4 scanme.nmap.org — full TCP port sweep across all 65535 ports
- **Service version detection:** nmap -sV scanme.nmap.org — identifies service names and version banners
- **OS fingerprinting:** nmap -O scanme.nmap.org — matches TCP/IP stack behaviour against Nmap's OS database
- **Default script scan:** nmap -sC -sV -O scanme.nmap.org — combines version detection, OS detection, and the default NSE (Nmap Scripting Engine) script set

2. Typical Enumeration Findings

scanme.nmap.org is a server intentionally maintained by the Nmap project for testing purposes, so it exposes a small, well-known set of ports:

Port / Service	Likely Purpose	Risk if Exposed	Risk Level
22/tcp – SSH	Remote administration	Brute-force login attempts, credential stuffing, exploitation of outdated OpenSSH versions	Medium
80/tcp – HTTP	Web service / landing page	Web application attacks, information disclosure, outdated web server exploits	Medium
9929/tcp – nping-echo (custom)	Testing service for Nmap's Nping tool	Unusual custom service; potential misconfiguration or forgotten test service	Low
31337/tcp – Elite/Back-orifice range (test)	Historically used for demonstration purposes only	Legacy/test port left open; not meant for production	Low

3. Business Purpose vs Necessity

- **SSH (22):** Needed for legitimate administrative access; should NOT be open to the entire internet without restriction (key-based auth, IP allow-listing recommended)

- **HTTP (80):** Needed if the server intentionally hosts a public web page; otherwise unnecessary exposure
- **Non-standard/test ports:** Not required for genuine public-facing business functions and should be closed on any production system — they exist here only because this host is a deliberate Nmap test target

4. How a Threat Actor Could Exploit This Information

- **Service exploitation:** Version banners obtained via `-sV` can be matched against known CVEs for that exact software build (e.g., an outdated OpenSSH or Apache version)
- **Brute-force attacks:** An open SSH port with password authentication enabled is a direct target for automated credential-guessing tools
- **Vulnerability discovery:** OS fingerprinting narrows down the underlying platform, letting an attacker select OS-specific exploits and rule out those that will not work
- **Attack chaining:** NSE default scripts (`-sC`) may reveal additional details such as HTTP titles, SSH host keys, or misconfigurations that assist in crafting a more targeted follow-on attack

5. Technical Report Summary — Attack Surface, Risk, Recommendations

- **Attack surface:** Limited to a small number of ports (SSH, HTTP, and legacy test services); overall surface is small but not zero
- **Risk assessment:** Medium risk overall — the open SSH and HTTP services are standard but must be kept patched and access-controlled; legacy/test ports pose low but unnecessary risk
- **Recommendations:** Enforce key-based SSH authentication and disable password login; restrict SSH access via firewall/allow-lists; keep all service software updated; close any ports not required for the server's actual function; enable logging and intrusion detection on exposed services

Q2. Enumeration of 192.168.56.101 (Metasploitable 2 – Lab)

1. Nmap Commands Used

- **Host discovery:** `nmap -sn 192.168.56.101`
- **Full TCP scan with version/OS/script detection:** `nmap -p- -sV -O -sC -T4 192.168.56.101`

2. Expected Open Ports and Services

Metasploitable 2 is a deliberately vulnerable Linux target used for training, so it exposes numerous outdated and insecure services:

Port / Service	Likely Purpose	Risk if Exposed	Risk Level
21/tcp – FTP (vsftpd 2.3.4)	File transfer	Contains a known backdoor vulnerability allowing remote root shell access	High
22/tcp – SSH	Remote administration	Weak/default credentials commonly used in lab images	Medium
23/tcp – Telnet	Remote login (unencrypted)	Credentials transmitted in clear text; easily intercepted	High
25/tcp – SMTP	Mail transfer	User enumeration via VRFY command, open relay misuse	Medium

139/445/tcp – Samba (SMB)	File/printer sharing	Vulnerable Samba versions allow remote code execution	High
512/513/514 – rlogin/rsh services	Legacy remote access	No authentication or weak trust-based authentication	High
1524/tcp – Ingreslock (backdoor shell)	Leftover backdoor from prior compromise	Provides direct unauthenticated root shell access	High
3306/tcp – MySQL	Database service	Default/weak credentials, unauthenticated access to data	Medium
5432/tcp – PostgreSQL	Database service	Default credentials, potential data exposure	Medium
8180/tcp – Apache Tomcat	Web application server	Default manager credentials allow remote WAR file deployment (RCE)	High

3. Risk Categorization Summary

- **High risk:** FTP backdoor, Telnet, Samba, rlogin/rsh, Ingreslock backdoor, and Tomcat manager — all provide direct or near-direct paths to code execution or credential theft
- **Medium risk:** SSH, SMTP, MySQL, PostgreSQL — exploitable mainly through weak credentials or information disclosure rather than direct RCE
- **Low risk:** Any standard services running current, properly configured software with no known default-credential issues (minimal in this intentionally vulnerable image)

4. How Enumeration Guides Attack Vector Selection

- **Prioritization:** A tester uses the risk categorization to attack the highest-impact, lowest-effort vulnerabilities first (e.g., the vsftpd backdoor or Ingreslock shell) for a quick foothold
- **Exploitation strategy:** Version-specific findings (e.g., vsftpd 2.3.4) are matched directly to known exploit modules such as those in the Metasploit Framework
- **Lateral movement planning:** Discovering multiple services (databases, file shares) suggests possible pivot points once initial access is gained
- **Realistic training value:** The mix of high, medium, and low risk services allows a trainee to practice prioritization and exploitation methodology in a safe, legal environment

Q3. Enumeration of 192.168.56.102 (Windows Workstation)

1. Nmap Commands Used

- **Host discovery:** `nmap -sn 192.168.56.102`
- **Comprehensive enumeration:** `nmap -p- -sV -O --script=smb-os-discovery,smb-enum-shares,smb-enum-users -T4 192.168.56.102`

2. Typical Findings on a Windows Workstation

Port / Service	Likely Purpose	Risk if Exposed	Risk Level
----------------	----------------	-----------------	------------

135/tcp – MSRPC	Remote procedure calls for Windows services	Can be leveraged for remote enumeration and certain RPC-based exploits	Medium
139/445/tcp – SMB / NetBIOS	File and printer sharing	Enumeration of shares/users, EternalBlue-class exploits if unpatched	High
3389/tcp – RDP	Remote Desktop (remote management)	Brute-force login, credential relay, BlueKeep-class exploits if unpatched	High
5357/tcp – WSDAPI / Network Discovery	Device/service discovery on the LAN	Minor information disclosure about the host	Low
Dynamic high ports (49152+) – RPC endpoints	Windows service RPC endpoint mapper range	Expands attack surface for RPC-based services	Low-Medium

3. Least-Privilege / Attack-Surface Analysis

- **Unnecessary exposure:** File-sharing (SMB) and RDP should not be reachable from untrusted network segments before the machine joins the hardened production network
- **Least privilege violation:** Open administrative shares (e.g., C\$, ADMIN\$) or guest access on SMB violate least-privilege principles by allowing more access than required
- **Justified services:** Only services essential to the workstation's actual business function (e.g., domain communication ports, if managed centrally) should remain enabled

4. Attacker Use Cases

- **Reconnaissance:** smb-enum-shares and smb-enum-users scripts can reveal usernames and share names useful for password-guessing and social engineering
- **Lateral movement:** SMB and RDP are classic pivot points once an attacker has valid or cracked credentials, enabling movement across the internal network
- **Unauthorized access:** Weak RDP credentials or missing network-level authentication (NLA) can allow direct remote takeover of the workstation

5. Recommended Hardening Measures

- **Disable unused services:** Turn off SMBv1, unnecessary file sharing, and RDP if not required; if RDP is required, restrict it via VPN/jump host and enable NLA
- **Patch management:** Apply current OS and application patches before connecting the workstation to production
- **Host-based firewall:** Restrict inbound access to only the ports/services genuinely required, from only the required source IP ranges
- **Account hardening:** Enforce strong password policy, disable default/guest accounts, and use least-privilege user accounts
- **Endpoint monitoring:** Deploy endpoint detection and logging before the machine is trusted on the production network

Q4. Enumeration of 192.168.56.103 (OWASP Juice Shop Web Server)

1. Nmap Commands Used

- **Host discovery:** `nmap -sn 192.168.56.103`
- **Port scan + service/OS detection:** `nmap -p- -sV -O -T4 192.168.56.103`
- **Web service identification:** `nmap -sC -p80,443,3000 --script=http-title,http-headers,http-methods 192.168.56.103`

2. Typical Findings

Port / Service	Likely Purpose	Risk if Exposed	Risk Level
3000/tcp – Node.js/Express (Juice Shop app)	Hosts the OWASP Juice Shop web application	Exposed intentionally vulnerable e-commerce app: SQLi, XSS, broken auth, etc.	High
22/tcp – SSH (host OS)	Server administration	Brute-force or credential-based compromise of the underlying host	Medium
80/443 – HTTP/HTTPS (if reverse proxy present)	Front-end web access / TLS termination	Weak TLS configuration, missing security headers	Medium
Admin/API endpoints (e.g., /rest/, /api/)	Application REST API for the Juice Shop app	Broken access control, exposed admin functionality	High

3. How Discovered Services Support the Web Application

- **Application port (3000):** Directly serves the Juice Shop front-end and REST API — this is the primary attack surface for the penetration test
- **Supporting infrastructure:** SSH supports administration of the underlying host; a reverse proxy (if present) supports TLS termination and routing

4. Risk Evaluation

- **Exposed web services:** Direct access to the application port allows unauthenticated interaction with all client-side and API functionality, the intended target for the test
- **Administrative interfaces:** If any admin panel or API management endpoint is reachable without authentication, it significantly raises risk
- **Supporting services:** An exposed SSH or misconfigured reverse proxy could allow attackers to bypass the application layer entirely and compromise the host directly

5. How Enumeration Feeds Vulnerability Identification

- **Technology fingerprinting:** Identifying Node.js/Express and associated HTTP headers/banners helps map to known framework-level vulnerabilities
- **Endpoint discovery:** `http-title`, `http-methods`, and directory-style NSE scripts reveal accessible paths, forming the starting point for OWASP Top 10 testing (SQLi, XSS, broken authentication, etc.)
- **Attack planning:** Enumeration results allow a tester to move from network-level reconnaissance directly into application-level testing

6. Recommendations to Minimize Exposure

- **Network segmentation:** Keep the test/staging application isolated from production networks and the public internet
- **Restrict administrative access:** Limit SSH and any admin endpoints to specific management IP ranges

- **Secure headers and TLS:** Enforce HTTPS with strong TLS configuration and standard security headers (CSP, X-Frame-Options, etc.) on any production-facing deployment
- **Regular vulnerability scanning:** Continuously scan the web application and supporting services for newly disclosed vulnerabilities

Q5. Enumeration of 192.168.56.1 (Network Gateway Device)

1. Nmap Commands Used

- **Host discovery:** `nmap -sn 192.168.56.1`
- **Comprehensive enumeration:** `nmap -p- -sV -O -sC -T4 192.168.56.1`
- **Script-based management-service enumeration:** `nmap --script=snmp-info,http-title,ssh2-enum-algos,telnet-encryption 192.168.56.1`

2. Typical Findings on a Gateway Device

Port / Service	Likely Purpose	Risk if Exposed	Risk Level
22/tcp – SSH	Encrypted remote management	Brute-force attempts, outdated SSH implementations	Medium
23/tcp – Telnet	Legacy remote management (unencrypted)	Cleartext credentials, trivial interception on the LAN	High
80/443 – HTTP/HTTPS management UI	Web-based device configuration	Default credentials, weak session management, exposed config pages	High
161/udp – SNMP	Network monitoring/management	Default community strings (e.g., 'public') expose device configuration and traffic data	High
53/tcp/udp – DNS (if gateway also resolves)	Name resolution for internal network	DNS cache poisoning, information disclosure	Medium

3. Security Implications of Exposed Management Services

- **SSH:** Should be the preferred management protocol, but must use strong authentication and be restricted to management subnets
- **Telnet:** Should never be enabled — all traffic including passwords is transmitted in plaintext, making it trivial to intercept on the local network
- **SNMP:** Default/weak community strings can allow attackers to read (and sometimes write) device configuration remotely, exposing the entire network topology
- **HTTP/HTTPS management interface:** Often the most attacked surface on gateway devices; default admin credentials and unpatched firmware are common entry points

4. How Attackers Exploit Misconfigured Management Services

- **Credential attacks:** Weak/default credentials on Telnet, HTTP admin panels, or SNMP community strings allow attackers to log in directly
- **Configuration tampering:** Once authenticated, an attacker can alter routing rules, DNS settings, or firewall rules to intercept or redirect traffic (man-in-the-middle)

- **Network-wide compromise:** Because the gateway sits at the network boundary, compromising it can expose or reroute traffic for every internal host, making it a high-value target
- **Persistence:** Attackers may modify firmware or configuration to maintain long-term undetected access to the network

5. Recommended Security Controls

- **Disable insecure protocols:** Turn off Telnet entirely; use SSH (with key-based authentication) for command-line management
- **Harden SNMP:** Disable SNMP if unused, or upgrade to SNMPv3 with strong authentication/encryption and change default community strings
- **Restrict management access:** Limit access to the web/SSH/SNMP management interfaces to a dedicated management VLAN or specific trusted IP addresses
- **Strong credentials and MFA:** Replace default credentials immediately and enable multi-factor authentication on the management interface where supported
- **Firmware updates:** Keep gateway firmware current to patch known vulnerabilities
- **Logging and monitoring:** Enable audit logging of all management access attempts and alert on anomalies

Code of Conduct

I P Delhi Ganesh / 192521434 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.